

Issue	Mapped Control	Control Category	Impact to Control	Reasoning (1-2 sentences)	Affected Risk(s)	Residual Risk Update	Why Did You Update It?
Multiple employees opted out of MFA during onboarding because the setup instructions were outdated and confusing.	MFA Configuration	Preventive	Ineffective	If users can simply bypass MFA setup, the technical enforcement of the control is broken.	Risk-002, Risk-001	Increasing	Without enforced MFA, accounts are highly vulnerable to credential compromise.
Quarterly vulnerability scans were completed, but the reports were emailed to a security analyst who is no longer with the company, and no one followed up.	Vulnerability Scans / Offboarding	Detective	Ineffective	The detective control fails completely if alerts go to an unmonitored inbox.	Risk-010	Increasing	Unreviewed vulnerabilities remain unpatched and exploitable by attackers.
Access reviews were sent to managers, but half didn't complete them because the tool didn't notify them after the initial email.	Access Reviews	Detective	Partially Effective	The process is in place, but poor tool workflows leave 50% of access completely unchecked.	Risk-003, Risk-006	Increasing	Unreviewed access means departed or over-privileged users likely retain permissions.
HR uploaded a spreadsheet containing employee SSNs to a shared Google Drive folder that allows link-based access.	RBAC / Privacy Controls	Preventive	Ineffective	The access controls failed to restrict highly sensitive internal PII to authorized HR personnel.	Risk-004	Increasing	Employee PII is actively exposed to unauthorized internal staff.
The team uses shared admin accounts for Salesforce, making it impossible to track who made changes.	Identity & Access Management	Preventive	Ineffective	Shared accounts completely break accountability and render audit logging useless.	Risk-002, Risk-005	Increasing	You cannot trace malicious or accidental changes back to a specific individual.
A new intern was granted admin permissions in Notion by mistake, and it wasn't discovered for 3 weeks.	Role-Based Access Control (RBAC)	Preventive	Ineffective	Provisioning failed initially, and it took far too long to detect the excessive privilege.	Risk-008	Increasing	Three weeks of unauthorized admin access gives ample time for data corruption.
GitHub repo settings were changed by a contractor because the default permissions still allowed external collaborators from a previous project.	Offboarding / Access Reviews	Preventive	Ineffective	Failure to remove external access leaves proprietary intellectual property exposed.	Risk-006	Increasing	External contractors could maliciously or accidentally alter core company IP.
Users report they've been able to reuse their old passwords even though policy says they shouldn't.	Password Policy Enforcement	Preventive	Ineffective	The technical enforcement of the policy is failing if users can bypass it.	Risk-007	Increasing	Reused passwords greatly increase the company's susceptibility to credential stuffing.

Issue	Mapped Control	Control Category	Impact to Control	Reasoning (1-2 sentences)	Affected Risk(s)	Residual Risk Update	Why Did You Update It?
After privilege escalation alerts were turned on in Okta, they generated too many false positives and were disabled.	Logging & Monitoring Setup	Detective	Ineffective	A disabled detective control provides zero monitoring value to the organization.	Risk-007	Increasing	Privilege escalation will now go completely unnoticed.
The data backup schedule was missed twice last quarter due to a misconfigured automation script.	Data Backup Verification	Corrective	Partially Effective	Backups work most of the time, but reliability is degraded by automation bugs.	Risk-005	Increasing	Missed backups mean a higher volume of data will be permanently lost during a failure.
Risk acceptance memos were stored in an employee's email inbox and never uploaded to the risk register.	GRC Process / Risk Management	Preventive	Ineffective	Decentralized tracking means leadership lacks visibility into accepted organizational risks.	Risk-010	Increasing	Risks cannot be managed or monitored if they are hidden in a personal inbox.
A Confluence page containing sensitive customer issue data was accidentally marked public and indexed by Google.	Data Privacy / Access Control	Preventive	Ineffective	Misconfiguration allowed internal data to bypass all access controls and become public.	Risk-009	Increasing	Sensitive customer data is now publicly searchable on the internet.
Control owners submitted evidence for the audit, but over 30% of the screenshots were outdated or missing required metadata.	Compliance Monitoring	Detective	Partially Effective	Evidence is being collected, but poor quality hinders audit assurance.	Risk-011	Increasing	Poor evidence quality directly threatens the company's SOC 2 compliance status.
The SOC 2 remediation plan was created, but no one was assigned as the DRI for follow-up.	Incident Response / Remediation	Corrective	Ineffective	Without an assigned owner, the remediation tasks will not be completed.	Risk-011	Increasing	Known security flaws remain unpatched without accountability.
There is no record of legal reviewing updated customer contracts after a major privacy policy change.	Legal & Compliance Review	Preventive	Ineffective	Bypassing legal review creates massive regulatory and contractual liability.	Risk-004	Increasing	The company could unknowingly be in breach of privacy laws or customer SLAs.
Zendesk does not currently log IP addresses for agent access, despite this being a requirement in the security policy.	Logging & Monitoring Setup	Detective	Partially Effective	Some logging exists, but missing IP data breaks security policy requirements.	Risk-007	Increasing	It is much harder to investigate suspicious logins without IP address data.

Issue	Mapped Control	Control Category	Impact to Control	Reasoning (1-2 sentences)	Affected Risk(s)	Residual Risk Update	Why Did You Update It?
Some Jira tasks containing security findings were closed automatically due to inactivity after 30 days.	Vulnerability Management	Corrective	Ineffective	Closing tickets without fixing the flaws means vulnerabilities are ignored.	Risk-010	Increasing	Automated closure leaves critical systems exposed to attackers indefinitely.
Engineers bypass the official code deployment pipeline because it's slower than manual deployment.	Change Management Controls	Preventive	Ineffective	Bypassing the pipeline avoids automated security checks and peer reviews.	Risk-006	Increasing	Manual deployments introduce a high risk of human error or malicious code insertion.
A Tableau dashboard was published using test data, but users interpreted it as real client data and shared it with a partner.	Data Integrity / Training	Preventive	Ineffective	Lack of clear data classification led to the external sharing of unverified info.	Risk-005	Increasing	Sharing inaccurate dashboards damages company reputation and partner trust.
When asked about their responsibilities during the audit, two department heads said they had never seen the information security policy.	Security Awareness Training	Preventive	Ineffective	A policy cannot be enforced if leadership is entirely unaware of its existence.	All Risks	Increasing	Ignorance of policy at the leadership level guarantees a poor security culture.

Risk Category	Residual Risk Score	Risk Number	Probability (Residual Likelihood)	Impact (Residual)
Authentication / Account Security Risk	25	Risk-001	5	5
Authentication / Account Security Risk	16	Risk-002	4	4
Data Exposure / Access Control Risk	15	Risk-003	5	3
PII / Data Privacy Risk	20	Risk-004	5	4
Data Integrity / Process Risk	12	Risk-005	4	3
Insider Threat / Access Management Risk	16	Risk-006	4	4
Identity and Access Management Risk	20	Risk-007	4	5
Access Control / Data Integrity Risk	12	Risk-008	4	3
Data Exposure / Encryption Risk	15	Risk-009	5	3
GRC Process / Compliance Risk	16	Risk-010	4	4
Compliance / Residual Vulnerability Risk	16	Risk-011	4	4